HCML Monitoring Portal: Server flow (one request through the BFF)

Browser
nginx portal-web
Fastify portal-bff
TTL cache in memory
Zabbix API JSON-RPC 2.0
Mail server SMTP, optional
portal-state volume
1 GET /bff/api/sites Cookie: hcml_session=<jwt>
2 GET /api/sites Host with its port, X-Forwarded-For preserved
The plugin chain, in registration order
3 helmet: security headers CSP off: this process serves JSON only
4 CORS: one allowed origin (WEB_ORIGIN)
5 rate limit: per IP, before auth, so a flood is rejected before JWT work
6 compression hook: brotli / gzip
alt [rate limit exceeded]
7 429 rate_limited "the limit is N per minute"
onRequest: forgery check, then the auth guard
8 forgery check, unsafe methods only: a cookie POST needs X-HCML-CSRF: 1 and an Origin naming this host
9 verify the JWT: Bearer header, else the cookie. Never ?token=, not even on the stream
10 requiredRole(url): first match wins, anything unmatched needs viewer
alt [cookie POST without the header, or from another site]
11 403 csrf, before any token is checked
[no or bad token]
12 401 unauthorized: "Sign in to continue."
[role too low]
13 403 forbidden: names the role needed
14 cached("sites", 15 s, fn)
alt [fresh, within TTL]
15 the stored value
no Zabbix call at all
[another request is already fetching]
16 await the same promise
coalesced: twenty NOC screens cost one upstream read
[stale but inside staleMs]
17 the old value, now
18 one background refresh
a failed refresh keeps the old value and is logged, not thrown
[miss]
19 host.get · problem.get · trigger.get · item.get
20 raw JSON-RPC result
21 store, LRU, max 500 keys
The part Zabbix cannot do
22 resolveSite(): tag, then host name, then inventory, then group
23 roll hosts up per site, worst severity wins
24 200 application/json content-encoding: br
25 same, unbuffered
When Zabbix does not cooperate
26 token rejected → 503 zabbix_auth "fix the token", not an opaque 500
27 no answer in ZABBIX_TIMEOUT_MS → 503 zabbix_timeout
28 JSON-RPC error → 502 zabbix_error, a fixed sentence (Zabbix's own words go to the log)
the address in ZBX_URL goes to the log, never into the response body
The one write to Zabbix, for comparison
29 POST /api/problems/acknowledge, operator only the cookie plus X-HCML-CSRF: 1
30 event.acknowledge, on the SEPARATE write token
31 invalidate("problems", holdMs)
32 push the new list to every open screen at once
The report by email: administrators only, and off until MAIL_ is set
33 POST /api/sli/email the cookie plus X-HCML-CSRF: 1
34 month, files and addresses checked: one to ten, inside MAIL_ALLOWED_DOMAINS, five sends an hour each
35 log in first, so a wrong password fails in a second
36 the month's SLA, both methods from the cache, or from Zabbix on a miss
37 one message: the figures in the text, the files attached
38 the record of the send: counts and a word, never an address
39 how many addresses the mail server took
On the chosen day the scheduler does the same without a browser, and saves each step to the state file before the next
Browser
nginx portal-web
Fastify portal-bff
TTL cache in memory
Zabbix API JSON-RPC 2.0
Mail server SMTP, optional
portal-state volume